

Ernst & Young Remediation Plan

Introduction:

On Saturday, March 28th, 2026, Ernst & Young (EY) suffered an intrusion via a third-party IT service management platform, used to log and track internal tickets. The unauthorized access remained until Sunday, April 12th, 2026, totaling 15 days. The Internal Ticketing system tracks logs of simple tasks performed by the IT Service Desk team such as account recovery, Single Sign-On reset, and other basic troubleshooting concerns on user accounts at EY that have access to thousands of sensitive customer tax data, including Social Security Numbers, Date of Birth, Addresses, and other Personally Identifiable Information (PII). Internal Ticketing System Platforms (ITSM) are often overlooked and seen as “internal plumbing” (tech-insider, 2026), an easily overlooked requirement of a team designed to maintain operations and being the first to be dispatched should a device shut down or become inoperable. On Monday, July 27th, 2026 the ShinyHunters extortion group publicly claimed responsibility for the breach, threatening a data leak if EY does not respond by Saturday, July 31st, 2026; as of this writing, EY has not confirmed this attribution.

1. Purpose:

This policy establishes requirements for assessing, monitoring, and managing security risks associated with third-party platforms and vendors that process, store, interact, or transmit client data on behalf of EY.

2. Scope:

Applies to all third-party platforms or vendors including IT service platforms and services such as ticketing systems, that handle or interact with client PII or financial data.

3. Framework Alignment:

Controls in this policy are informed by NIST SP 800-161 Rev. 1 (Cybersecurity Supply Chain Risk Management) for third-party/vendor risk, with data handling controls aligned to NIST SP 800-53 MP (Media Protection) and SC-28 (Protection of Information at Rest).

a. Policy Statement(s):

- i. **Vendor Level System – All third-party vendors are assigned an access tier based on the sensitivity level of the data they handle and the level of access required to perform their duties.**

1. **Level 1** – Handles regulated or sensitive data.
2. **Level 2** – Handles internal data.

3. Level 3 – Handles non-sensitive data.

ii. Data Attachment Restrictions:

1. Level 1 platforms such as support ticketing systems shall not permit attachment of documents containing PII such as SSNs (Social Security Number), DOBs (Date of Birth), or Driver's License numbers without DLP (Data Loss Protection) scanning and redaction.
2. Monitoring and DLP logs shall capture file metadata only (filename, hash, timestamp, user, action type) and shall not retain full document content, screenshots, or unredacted copies of scanned data. Retaining full content in logs would create a secondary, less-controlled copy of the same sensitive data the control is meant to protect.
3. All attachments and associated metadata on Level 1 platforms shall be encrypted at rest (AES-256 or equivalent), independent of DLP classification outcome. Encryption at rest protects data if underlying storage is compromised or stolen, but does **NOT** substitute for DLP detection controls, since a session using valid, authorized credentials (the access pattern in the EY incident) can still view or export decrypted data during normal use.

iii. Anomaly Detection SLA:

1. Level 1 vendor platforms are subject to continuous monitoring with all anomalies to be investigated no later than 72-hours from discovery. (*Ref. EY 2026 incident, ~3-week undetected access*)

iv. Sensitive Ticket Handling:

1. Tickets classified as Level 1 (involving regulated or sensitive data) shall be handled only by escalated/senior support staff, not first-tier representatives. Before accessing a Level 1 ticket, staff **MUST** close all unrelated tickets, sessions, and applications to prevent cross-contamination or accidental exposure of unrelated client data.

4. Roles & Responsibilities:

- a. **Vendor Risk Owner:** Review and re-tier vendors annually.
- b. **IT Security:** Implement DLP and monitoring controls.
- c. **Legal:** Ensure contractual right-to-audit clauses and future changes in legislative policies such as new requirements to meet compliance.

5. Enforcement:

- a. Non-compliance in any capacity shall be flagged for remediation or vendor termination within 30-90 days depending on risk level.

- b.** Final approval for vendor remediation plans or termination decisions rest with the Vendor Risk Owner, in consultation with Legal for contractual/termination implications.
- 6. Review Cycle:**
 - a.** Annual review or upon vendor security incident.

References

Ernst & Young. (2026, July 15). Notification of Data Breach [Letter filed with the California Attorney General's Office]. Retrieved via classaction.org: <https://www.classaction.org/data-breach-lawsuits/ernst-and-young-july-2026>

Rescana. (2026, July 19). Ernst & Young Data Breach Analysis: Third-Party IT Support Platform Compromise Exposes Client Tax and Financial Information. <https://www.rescana.com/post/ernst-young-data-breach-analysis-third-party-it-support-platform-compromise-exposes-client-tax-and-financial-information>

Okunyè, P. (2026, July 27). ShinyHunters claims EY breach, warns all stolen data will be released. Cybernews. <https://cybernews.com/security/shinyhunters-ey-data-breach-ransomware/>

Note: Attribution claimed by threat actor; not confirmed by EY as of this writing.

Tech-Insider. (2026, July 29). EY Vendor Breach: Tax Data Exposed, 81-Day Silence. <https://tech-insider.org/ey-vendor-breach-tax-data-2026/>